

GUÍA COMPLETA DE CERTIFICADOS EN WINDOWS

Para el examen de Seguridad de Datos

certmgr, certlm, PowerShell, formatos de certificado, exportación, importación y firma PDF

Estructura

Contenido basado en la Práctica 2.2 – Integridad y Autenticidad: Funciones Resumen y Certificados

HERRAMIENTAS DE GESTIÓN

Acceso rápido

Herramienta	Comando	Alcance
Gestor de certificados de usuario	certmgr.msc	Solo certs del usuario actual
Gestor de certificados de equipo	certlm.msc	Todos los certs del equipo (requiere admin)
PowerShell ISE	powershell_ise	Editor + consola para scripts
PowerShell	powershell	Solo consola

También desde menú: Inicio → buscar “Certificados” → aparecen ambas herramientas.

Consejo

CONSEJO: certmgr.msc = usuario actual. certlm.msc = equipo local (necesario para IIS). En el examen, si hay que instalar un cert para que lo use el servidor IIS, usar certlm.msc.

APARTADO 1: Estructura del Almacén de Certificados

Almacenes principales (en certmgr.msc — usuario)

Almacén	Qué contiene
Personal	Certificados del usuario con su clave privada asociada
Entidades de certificación raíz de confianza	Certificados de ACs raíz en las que confía el sistema
Entidades de certificación intermedias	ACs intermedias (no raíz)
Otras personas	Certs de otros usuarios (solo clave pública)

Propiedades de un certificado — tres pestañas

Pestaña	Información disponible
General	Propósito, Emitido para, Emitido por, Periodo de validez
Detalles	Todos los campos del certificado (clave pública, algoritmo, etc.)
Ruta de certificación	Cadena completa hasta la raíz + estado de validez

Importante

IMPORTANTE: En un certificado RAÍZ: “Emitido para == Emitido por” (se firma a sí mismo). En un cert NO raíz: “Emitido por” es la AC que lo firmó.

Huella digital y localización en disco

El certificado se almacena en el sistema con el nombre de su huella digital (Thumbprint).

Directorio de certificados:

↪ C:\Users\Usuario\AppData\Roaming\Microsoft\SystemCertificates\My\Certificates

Directorio de claves: C:\Users\Usuario\AppData\Roaming\Microsoft\SystemCertificates\My\Keys

Consejo

CONSEJO: Para ver archivos ocultos en el Explorador de Windows: Ver → Opciones → Ver → "Mostrar archivos, carpetas y unidades ocultos". La carpeta AppData está oculta por defecto.

Importante

IMPORTANTE: Al eliminar un certificado con certmgr, el fichero de certificado se borra PERO la clave privada asociada NO se elimina automáticamente. Hay que borrar el fichero de claves manualmente si no se quiere retener la clave privada en el sistema.

APARTADO 2: Crear Certificados con PowerShell

Preparar PowerShell — política de ejecución

```
Get-ExecutionPolicy # comprobar política actual
Set-ExecutionPolicy -Scope CurrentUser Unrestricted # permitir ejecución de scripts
```

Verificar que la política persiste al reabrir PowerShell:

```
Get-ExecutionPolicy # debe devolver Unrestricted
```

Crear un Certificado Raíz (Autoridad Certificadora)

Guardar como CertificadoRaiz.ps1. El carácter “`” es continuación de línea (Alt+96):

```
$cert = New-SelfSignedCertificate -Type Custom `
    -Subject "CN=zpac.as" `
    -KeyAlgorithm RSA -KeyLength 2048 -KeySpec Signature -KeyExportPolicy Exportable `
    -KeyUsageProperty All -KeyUsage None `
    -Provider "Microsoft Enhanced RSA and AES Cryptographic Provider" `
    -NotBefore (Get-Date) `
    -NotAfter (Get-Date).AddYears(10) `
    -HashAlgorithm sha256 `
    -TextExtension @("2.5.29.19={critical}{text}ca=1") `
    -CertStoreLocation "Cert:\CurrentUser\My"
```

El resultado queda en la variable \$cert y en el almacén Personal del usuario.

Crear un Certificado de Servidor

Requiere que \$cert (el cert de la AC) esté cargado en la sesión PowerShell. Si se cerró PowerShell, recargar la variable:

```
Get-ChildItem Cert:\CurrentUser\My # ver thumbprints disponibles
$cert = Get-ChildItem Cert:\CurrentUser\My\<THUMBPRINT_DE_ZPAC>
```

Script del certificado de servidor:

```
New-SelfSignedCertificate -Type Custom `
    -Subject "CN=zpsr.as" -DnsName "zpsr.as", "www.zpsr.es", "www.zpsr.com" `
    -KeyAlgorithm RSA -KeyLength 2048 -KeySpec KeyExchange -KeyExportPolicy Exportable `
    -KeyUsageProperty All -KeyUsage None `
    -Provider "Microsoft Enhanced RSA and AES Cryptographic Provider" `
    -NotBefore (Get-Date) `
    -NotAfter (Get-Date).AddYears(5) `
    -HashAlgorithm sha256 `
```

```
-Signer $cert `
-CertStoreLocation "Cert:\CurrentUser\My"
```

Crear un Certificado de Usuario

```
New-SelfSignedCertificate -Type Custom `
-Subject "CN=zpusu.as" -DnsName "zpusu.as" `
-KeyAlgorithm RSA -KeyLength 2048 -KeySpec KeyExchange -KeyExportPolicy Exportable `
-KeyUsageProperty All -KeyUsage None `
-Provider "Microsoft Enhanced Cryptographic Provider v1.0" `
-NotBefore (Get-Date) `
-NotAfter (Get-Date).AddYears(5) `
-HashAlgorithm sha256 `
-Signer $cert `
-CertStoreLocation "Cert:\CurrentUser\My"
```

Tabla de parámetros de New-SelfSignedCertificate

Parámetro	Descripción
-Type	Tipo: Custom, CodeSigningCert, DocumentEncryptionCert, SSLServerAuthentication
-Subject	Nombre del sujeto del certificado (CN=nombre)
-DnsName	Nombres DNS alternativos del sujeto (útil para servidores)
-KeyAlgorithm	RSA o ECDSA
-KeyLength	Longitud en bits de la clave (ej: 2048)
-KeySpec	Signature (firmar), KeyExchange (cifrar), None
-KeyExportPolicy	Exportable, ExportableEncrypted (defecto), NonExportable
-KeyUsageProperty	All, Decrypt, KeyAgreement, None, Sign
-KeyUsage	Usos: DigitalSignature, KeyEncipherment, None... (None = sin restricción)
-Provider	CSP a usar. SIEMPRE usar "Microsoft Enhanced RSA and AES Cryptographic Provider" para la AC para evitar limitaciones en el uso de claves privadas
-NotBefore	Inicio validez: (Get-Date)
-NotAfter	Fin validez: (Get-Date).AddYears(N)
-HashAlgorithm	Algoritmo hash: sha256
-TextExtension	Para indicar que es una AC: @("2.5.29.19={critical}{text}ca=1")
-Signer	Objeto \$cert del certificado firmante (para certs no raíz)
-CertStoreLocation	Cert:\CurrentUser\My o Cert:\LocalMachine\My (solo estos dos)

Importante

IMPORTANTE: -TextExtension con "ca=1" es necesario para que Firefox permita cargar el certificado raíz en su almacén de confianza. Sin este parámetro Firefox lo rechaza.

-KeySpec: Signature vs KeyExchange

El parámetro -KeySpec indica para qué se usará la clave privada del certificado:

Valor	¿Qué hace la clave privada?	¿Quién lo usa?
Signature	Solo firmar datos/certificados	Autoridad Certificadora (AC)
KeyExchange	Firmar Y cifrar/descifrar	Servidor o usuario final

Por qué la AC usa Signature: La CA nunca necesita descifrar datos de nadie — su única función es firmar certificados de otros. Restringir su clave a solo firma es una buena práctica de seguridad: si la clave privada de la AC se comprometiera, el daño queda limitado a la emisión de certificados falsos, pero no podría usarse para descifrar tráfico.

Por qué servidor y usuario usan KeyExchange: Un servidor TLS necesita tanto firmar (autenticarse

durante el handshake) como participar en el intercambio de claves simétricas de sesión (descifrar la clave de sesión que el cliente envía cifrada con la clave pública del servidor). Un usuario también puede necesitar descifrar mensajes que le envíen cifrados con su clave pública.

Sobre la validez (-NotAfter):

Tipo de certificado	Validez recomendada	Motivo
AC (zpac.as)	10 años	Cambiarla obliga a redistribuir a todos los clientes
Servidor (zpsr.as)	5 años	Se renueva periódicamente por seguridad
Usuario (zpusu.as)	5 años	Igual que el servidor

En entornos reales los certificados de servidor duran incluso menos (Let's Encrypt: 90 días).

APARTADO 3: Formatos de Certificado

Tabla de formatos

Formato	Extensión	Contiene	Legible bloc notas	Para qué sirve
DER binario	.cer	Solo cert (pub)	NO	Formato más común
Base 64	.cer	Solo cert (pub)	SÍ	Intercambio legible
PKCS#7	.p7b	Cert + cadena	Doble clic = certmgr	Cadenas de certificados
PKCS#12 / PFX	.pfx	Cert + clave priv	NO	Transferir con clave privada

Importante

IMPORTANTE: El formato .pfx NO es un "certificado" en sentido estricto, ya que incluye la clave privada. Abrirlo con doble clic lanza el asistente de IMPORTACIÓN, no el visor. Los formatos DER y Base64 (.cer) al hacer doble clic muestran el visor de certificados.

Consejo

CONSEJO: Para el examen recordar: DER = binario (no legible), Base64 = texto (legible), PKCS#7 = cadena de certs, PKCS#12/PFX = incluye clave privada.

Tabla para completar en examen

Formato	Extensión	Clave privada	Legible bloc notas	Uso principal
DER	.cer	NO	NO	Distribución estándar del cert público
Base64	.cer	NO	SÍ	Distribución en texto/intercambio legible
PKCS#7	.p7b	NO	NO (abre certmgr)	Cadenas de certificados
PKCS#12	.pfx	SÍ	NO	Transferencia cert + clave privada

Estructura

CLAVE: Solo PKCS#12 (.pfx) incluye clave privada. DER y Base64 comparten extensión .cer pero DER no se puede leer con bloc de notas y Base64 sí (empieza por "-----BEGIN CERTIFICATE-----"). Doble clic en .cer → visor de certificado. Doble clic en .pfx → asistente de importación. Doble clic en .p7b → se abre certmgr directamente.

APARTADO 4: Exportar Certificados

Exportar SIN clave privada (solo certificado público)

1. Abrir certmgr.msc → almacén Personal → seleccionar certificado
2. Clic derecho → "Exportar..." o menú Acción → Exportar
3. Asistente: "¿Exportar la clave privada?" → **No**
4. Elegir formato:

- DER binario (.CER) → recomendado para uso general
- Base 64 (.CER) → si necesitas abrirlo con bloc de notas
- PKCS#7 (.P7B) → para cadenas de certificados

5. Dar nombre al fichero (convenio: zpACas-DER.cer, zpACas-B64.cer, zpACas-PKCS7.p7b)

Nombres de fichero recomendados por la práctica:

- AC sin clave: zpACas.cer (DER, el más común)
- Servidor sin clave: zpSERas.cer
- Usuario sin clave: zpUSUas.cer

Exportar CON clave privada (PKCS#12 / PFX)

1. Asistente: “¿Exportar la clave privada?” → **Sí**
2. Formato: PKCS#12 (.PFX)
3. Opciones a seleccionar: **TODAS** excepto “Eliminar la clave privada si la exportación es correcta”
4. Cifrado: elegir TripleDES-SHA1 (evitar AES256-SHA256 por posibles problemas de compatibilidad)
5. Contraseña de protección:

Fichero	Contraseña recomendada en la práctica
zpACas.pfx	conacpfx (contraseña de la AC para el PFX)
zpSERas.pfx	conserpfx (contraseña del servidor para el PFX)
zpUSUas.pfx	conusupfx (contraseña del usuario para el PFX)

Importante

IMPORTANTE: La AC SOLO debe exportar su clave privada para hacer un BACKUP. No debe distribuirla. Solo el certificado público (zpACas.cer) es el que se distribuye.

APARTADO 5: Importar Certificados

Importar un certificado de usuario (con clave privada — .pfx)

1. Doble clic sobre zpUSUas.pfx → se abre el Asistente para importar certificados
2. Seleccionar **Usuario actual**
3. Confirmar la ruta del fichero
4. Introducir contraseña: conusupfx
5. Opciones:
 - Marcar la clave privada como exportable
 - Incluir propiedades extendidas del certificado
 - NO habilitar protección segura de clave privada
6. Almacén: elegir manualmente → Examinar → **Personal** → “Mostrar almacenes físicos” → seleccionar el almacén físico
7. Finalizar

Verificar con certmgr.msc que el certificado aparece en Personal.

Instalar el certificado de la AC en “Raíces de confianza”

Esto es necesario para que el sistema considere válidos todos los certificados emitidos por esa AC.

1. Doble clic sobre zpACas.cer → ventana Certificado → botón “Instalar certificado...”
2. Seleccionar **Usuario actual**
3. Almacén: elegir manualmente → **Entidades de certificación raíz de confianza**
 - En este caso NO marcar “Mostrar almacenes físicos” (dejar que elija el asistente)

4. Aceptar la advertencia de seguridad → Finalizar

Importante

IMPORTANTE: Al importar un .pfx, el sistema puede cargar automáticamente el certificado de la AC también en el almacén Personal (incorrecto). Hay que eliminarlo de Personal y cargarlo manualmente en "Entidades de certificación raíz de confianza".

Consejo

CONSEJO: Si el certificado no aparece tras importar, pulsar F5 o el botón "Actualizar" (flecha circular verde) en certmgr.msc.

APARTADO 6: Cadena de Certificación y Confianza

Por qué es necesaria la cadena de confianza

Un certificado solo es "válido" si el sistema puede trazar una ruta desde ese certificado hasta una AC raíz de confianza.

Estructura

zpusu.as —firmado por→ zpac.as —firmado por sí mismo→ (raíz de confianza)

Si zpac.as NO está en "Entidades de certificación raíz de confianza", el sistema muestra:

- "Windows no tiene suficiente información para comprobar este certificado"
- La pestaña "Ruta de certificación" mostrará error

Una vez instalado zpac.as como raíz de confianza:

- La ruta de certificación se muestra completa
- Estado: "Certificado válido"

Importante

IMPORTANTE: Al crear un nuevo anclaje de confianza (instalar cert raíz), el sistema confiará en TODOS los certificados emitidos por esa AC. Es una decisión de seguridad importante: solo instalar ACs en las que realmente se confía.

APARTADO 7: Firma de PDF con Adobe Reader

Requisitos previos

- Adobe Acrobat Reader instalado
- Certificado personal instalado en certmgr.msc (ej: certificado de la FNMT o zpusu.as)

Pasos para firmar un PDF

1. Abrir el PDF en Adobe Acrobat Reader
 2. Herramientas → "Utilizar un certificado" → "Firmar digitalmente"
 3. El cursor cambia a una cruz — arrastrar para definir el área de la firma
 4. Seleccionar el certificado a usar → "Continuar"
 5. Verificar detalles del certificado: "Ver detalles del certificado"
- Pestaña Detalles: información del certificado
 - Pestaña Revocación: estado de revocación
 - Pestaña Confianza: nivel de confianza del certificado
 - Pestaña Normativas: políticas aplicables
6. Verificar que "Bloquear el documento tras la firma" NO esté marcado (para permitir más firmas)

7. “Firmar” → guardar el fichero con un nuevo nombre

Importante

IMPORTANTE: Si marcas “Bloquear el documento tras la firma” NADIE más podrá firmarlo y además no podrá ser modificado. Usarlo solo si es la última firma del documento.

Panel de Firma

Tras firmar, aparece un banner en la parte superior. Acceder al Panel de Firma (esquina superior derecha) para:

- Ver información de cada firma
- Revisar los certificados empleados
- Verificar que las firmas son válidas

Crear un ID digital nuevo en Adobe Reader

Herramientas → Certificado → “Configurar un nuevo ID digital” → “Crea una ID Digital Nueva” → Guardar en el almacén de certificados de Windows → Establecer valores → Finalizar

Consejo

CONSEJO: Los certificados creados desde Adobe Reader son autofirmados y NO son certificados oficiales válidos. Solo sirven para pruebas o uso interno. No sirven para firmar documentos de forma oficial ante terceros.

APARTADO 8: Extensión KeyUsage — Usos permitidos de la clave

El campo **KeyUsage** en los detalles de un certificado restringe los usos permitidos de la clave privada asociada. Es una extensión del estándar X.509.

Valores más comunes

Valor	Significado
DigitalSignature	La clave privada puede firmar digitalmente datos (autenticación, no repudio)
KeyEncipherment	La clave privada puede descifrar claves simétricas cifradas con la clave pública
CertSign	La clave privada puede firmar otros certificados (exclusivo de ACs)
CRLSign	La clave privada puede firmar listas de revocación de certificados (CRL)
DataEncipherment	La clave privada puede descifrar datos directamente (poco habitual)
KeyAgreement	Para algoritmos de acuerdo de clave (ej: ECDH)
NonRepudiation	El titular no puede negar haber firmado (no repudio)

Combinación típica de un certificado de servidor TLS/HTTPS

KeyUsage: DigitalSignature, KeyEncipherment

- **DigitalSignature** → firma el handshake TLS para autenticarse ante el cliente
- **KeyEncipherment** → descifra la clave de sesión que el cliente envía cifrada con la clave pública del servidor (mecanismo RSA key exchange clásico)

Combinación típica de una AC

KeyUsage: CertSign, CRLSign

Solo puede firmar certificados y listas de revocación — no descifrar tráfico.

KeyUsage None (valor usado en la práctica)

En los scripts de la práctica se usa `-KeyUsage None`, lo que significa que el cmdlet NO añade la extensión `KeyUsage` al certificado. Sin esta extensión, la clave puede usarse para cualquier propósito. Es aceptable para pruebas, pero en producción siempre se deben restringir los usos.

Estructura

CONSEJO EXAMEN: Si ves "DigitalSignature, KeyEncipherment" → certificado de servidor/usuario.
Si ves "CertSign" → certificado de una AC. Si no aparece la extensión → sin restricción de uso.

CHULETA DE REFERENCIA RÁPIDA

Comandos de PowerShell

```
Get-ExecutionPolicy           # ver política actual
Set-ExecutionPolicy -Scope CurrentUser Unrestricted # permitir scripts
Get-ChildItem Cert:\CurrentUser\My           # listar certs + thumbprints
$cert = Get-ChildItem Cert:\CurrentUser\My\<THUMBPRINT> # cargar cert en variable
```

Herramientas

Estructura

certmgr.msc	Certs del usuario actual
certlm.msc	Certs del equipo local (admin) – necesario para IIS

Formatos de certificado

Formato	Extensión	Clave privada	Legible	Uso principal
DER	.cer	NO	NO	Distribución estándar del cert público
Base64	.cer	NO	SÍ	Distribución en texto
PKCS#7	.p7b	NO	No	Cadenas de certificados
PKCS#12	.pfx	SÍ	NO	Transferencia cert + clave privada

Contraseñas de la práctica

Fichero	Contraseña
zpACas.pfx	conacpfx
zpSERas.pfx	conserpfx
zpUSUas.pfx	conusupfx

Almacenes de certificados en certmgr.msc

Almacén	Para qué
Personal	Mis certs + clave privada
Entidades de certificación raíz de confianza	ACs raíz en las que confío
Otras personas	Certs de otros (solo clave pública)

Estructura

1. PS: New-SelfSignedCertificate para zpac.as (AC) → queda en Personal
2. PS: New-SelfSignedCertificate para zpser.as (servidor) con -Signer \$cert
3. PS: New-SelfSignedCertificate para zpusu.as (usuario) con -Signer \$cert
4. certmgr.msc → Exportar zpACas.cer en DER (sin clave privada)
5. certmgr.msc → Exportar zpACas.pfx en PKCS#12 (con clave privada → contraseña conacpfx)
6. certmgr.msc → Exportar zpSERas.cer en DER, zpSERas.pfx (contraseña conserpfx)
7. certmgr.msc → Exportar zpUSUas.cer en DER, zpUSUas.pfx (contraseña conusupfx)
8. En máquina cliente: doble clic zpUSUas.pfx → importar en Personal
9. En máquina cliente: doble clic zpACas.cer → Instalar cert → Raíces de confianza
10. Verificar cadena en certmgr.msc → zpusu.as → Ruta de certificación → "Certificado válido"

Trucos clave para el examen

1. Si el cert no aparece tras importar → pulsar F5 en certmgr
 2. Si la ruta de certificación da error → falta instalar el cert de la AC en “Raíces de confianza”
 3. El cert de la AC aparece en Personal tras importar un .pfx → eliminarlo y reinstalar en Raíces
 4. La clave privada NO se borra al eliminar el cert → borrar manualmente de My\Keys si es necesario
 5. Certificado raíz: “Emitido para == Emitido por” → se reconoce porque se firmó a sí mismo
- -TextExtension @("2.5.29.19={critical}{text}ca=1") — añade la extensión **Basic Constraints** (OID 2.5.29.19) marcada como crítica, indicando que este certificado es una CA (ca=1). Sin esta extensión, Firefox rechaza el certificado cuando intentas cargarlo en su almacén de raíces de confianza, porque Firefox valida estrictamente que un cert raíz tenga esa extensión marcada como crítica. Chrome/Edge (que usan el almacén de Windows) son más permisivos y no lo exigen, pero Firefox tiene su propio motor de validación.

AFIRMACIONES TÍPICAS DE EXAMEN — VERDADERO/FALSO

Basado en apuntes de práctica (firma y cadena de confianza).

1. “Una AC es un certificado que sirve para crear otros certificados e indicar que son reales y válidos.”

Veredicto: Correcto. La AC actúa como emisor/notario: firma certificados de usuarios y servidores. Al crearla en PowerShell se marca con la extensión ca=1 en Basic Constraints (2.5.29.19).

2. “Si vas a crear un certificado de usuario o servidor necesitas tener la AC con clave privada (.pfx) para poder firmar dichos certificados.”

Veredicto: Correcto, con matiz. Para emitir un cert hijo hace falta la **clave privada** de la AC (firmar con -Signer \$cert). El .pfx es el contenedor de backup/transporte (cert + clave privada); en sesión PowerShell se usa la clave cargada en el almacén, no necesariamente el fichero .pfx en ese momento.

3. “Si vas a firmar con uno de los certificados creados por la AC necesitas tener el .cer de esta para indicar que con el que firmas es de confianza.”

Veredicto: Correcto. Al firmar (p. ej. en Adobe), el sistema mira quién emitió tu certificado. Debes instalar la **clave pública** de la AC (zpACas.cer, sin clave privada) en **Entidades de certificación raíz de confianza** para crear el anclaje de confianza.

Importante

IMPORTANTE: Nunca distribuyas el .pfx de la AC a los clientes. Solo el .cer (público) va en raíces de confianza; el .pfx comprometería toda la PKI si se filtra.